Cyberscope

A TAC Security Company

Penetration Test Report

VaultedMetrics

March 2026

Audited by © cyberscope

Table of Contents

Table of Contents 1
Risk Classification 2
Review 3
Audit Updates 3
Overview 4
Penetration Assessment Scope 4
Findings Breakdown 5
Diagnostics 6
WCSS – Weak Cipher Suites Supported 7
Description 7
Recommendation 8
CA – Clickjacking Attack 9
Description 9
Recommendation 10
HSHM – HTTP Security Headers Misconfigured 11
Description 11
Recommendation 13
SCE - SSL Certificate Expiration 14
Description 14
Recommendation 15
Summary 16
Disclaimer 17
About Cyberscope 18

Risk Classification

The criticality of findings in Cyberscope's smart contract audits is determined by evaluating multiple variables. The two primary variables are:

1. **Likelihood of Exploitation**: This considers how easily an attack can be executed, including the economic feasibility for an attacker.
2. **Impact of Exploitation**: This assesses the potential consequences of an attack, particularly in terms of the loss of funds or disruption to the contract's functionality.

Based on these variables, findings are categorized into the following severity levels:

1. **Critical**: Indicates a vulnerability that is both highly likely to be exploited and can result in significant fund loss or severe disruption. Immediate action is required to address these issues.
2. **Medium**: Refers to vulnerabilities that are either less likely to be exploited or would have a moderate impact if exploited. These issues should be addressed in due course to ensure overall contract security.
3. **Minor**: Involves vulnerabilities that are unlikely to be exploited and would have a minor impact. These findings should still be considered for resolution to maintain best practices in security.
4. **Informative**: Points out potential improvements or informational notes that do not pose an immediate risk. Addressing these can enhance the overall quality and robustness of the contract.

Severity	Likelihood / Impact of Exploitation
Critical	Highly Likely / High Impact
Medium	Less Likely / High Impact or Highly Likely/ Lower Impact
Minor / Informative	Unlikely / Low to no Impact

Review

Domain	https://vaultedmetrics.io

Audit Updates

Initial Audit	05 March 2026

Overview

Cyberscope has conducted a comprehensive Black Box Penetration test for "VaultedMetrics" hosted at https://vaultedmetrics.io. This report evaluates the security and performance of the web application. The assessment encompasses key areas, including, but not limited to, the stability and availability of publicly accessible endpoints, network and transport security, configuration management, abuse-prevention mechanisms (e.g., rate limiting and throttling), and behavior under high concurrency and traffic bursts.

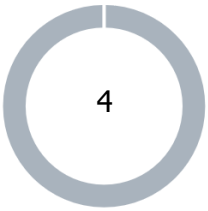
With the expansion of blockchain technology and related integrations, web application-specific misconfigurations and security weaknesses can directly impact data confidentiality, integrity, and availability. As a core interface within a digital currency ecosystem, VaultedMetrics must ensure robust protection of sensitive information and maintain reliable operation across all exposed endpoints.

Penetration Assessment Scope

The scope of this assessment focuses on identifying vulnerabilities and weaknesses within the publicly accessible web application and endpoint implementations, with the objective of providing actionable recommendations to strengthen its security posture. The evaluation covered all accessible components, including transport and network security, configuration management, error handling, caching behavior, abuse-prevention mechanisms (e.g., rate limiting and throttling), and operational behavior under varying load conditions. Particular attention was given to common web application security risks and misconfigurations referenced in industry standards such as the OWASP Top 10, including security misconfiguration, sensitive information exposure, improper access or authorization controls, insecure communication practices, and availability-related issues.

This report aims to deliver a comprehensive understanding of the web application's security strengths and areas for improvement, enabling informed decisions to mitigate risks, defend against potential threats, and enhance overall security resilience for VaultedMetrics programmatic interfaces.

Findings Breakdown



Critical	0
Medium	0
Minor / Informative	4

Severity	Unresolved	Acknowledged	Resolved	Other
Critical	0	0	0	0
Medium	0	0	0	0
Minor / Informative	4	0	0	0

Diagnostics

Critical Medium Minor / Informative

Severity	Code	Description	Status
●	WCSS	Weak Cipher Suites Supported	Unresolved
●	CA	Clickjacking Attack	Unresolved
●	HSHM	HTTP Security Headers Misconfigured	Unresolved
●	SCE	SSL Certificate Expiration	Unresolved

WCSS – Weak Cipher Suites Supported

Criticality	Minor / Informative
Status	Unresolved
CWE ID:	326
CVSS3 Score:	3.2

Description

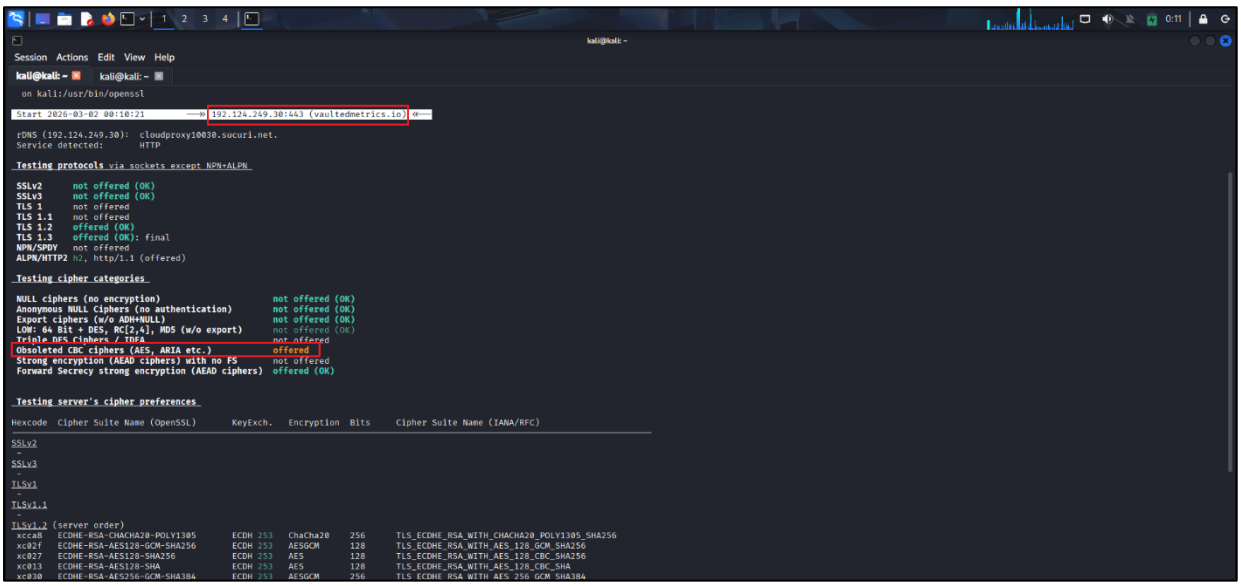
It is observed that the server supports multiple weak and outdated TLS cipher suites, including CBC-mode ciphers and RSA key exchanges without forward secrecy. These cipher suites are vulnerable to cryptographic attacks such as padding oracle attacks, downgrade attacks, and known weaknesses in legacy encryption algorithms.

An attacker positioned as a man-in-the-middle (MITM) could exploit these weaknesses to intercept encrypted traffic, manipulate communications, or potentially decrypt sensitive information transmitted between the client and server. In cases where forward secrecy is not enforced, previously captured encrypted sessions could be decrypted if the server's private key is later compromised.

Vulnerable URL / HOST:

- https://vaultedmetrics.io/

Proof of Concept: The screenshot below shows that the server is using weak cipher suites.



Recommendation

It is recommended to disable all weak and legacy cipher suites, especially those using CBC mode and non-ephemeral RSA key exchanges. Configure the server to support only strong, modern cipher suites that provide forward secrecy, such as AES-GCM and ChaCha20-Poly1305 with ECDHE key exchanges. Prioritize the use of TLS 1.3 cipher suites and ensure TLS 1.2 configurations follow current security best practices. Regularly review and update the TLS configuration in alignment with industry standards and security benchmarks to ensure ongoing protection against cryptographic attacks and evolving threats.

CA – Clickjacking Attack

Criticality	Minor / Informative
Status	Unresolved
CWE ID:	1021
CVSS3 Score:	3.1

Description

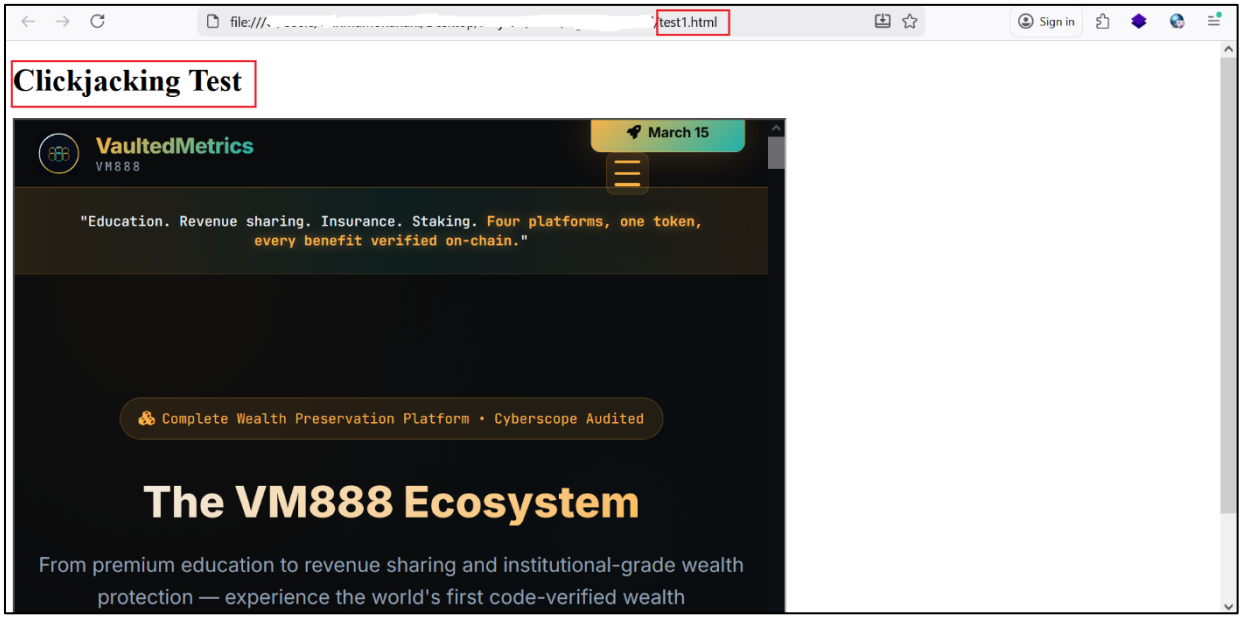
It is observed that the web application does not implement sufficient clickjacking protection mechanisms. Specifically, HTTP headers such as X-Frame-Options or a properly configured Content-Security-Policy frame-ancestors directive are missing or improperly configured.

An attacker can exploit this weakness by embedding the application in a malicious iframe on another site, tricking users into performing unintended actions (e.g., clicking buttons or links) without their knowledge. This can result in unauthorized transactions, changes in account settings, or other actions being performed on behalf of the user.

Vulnerable URL / HOST:

- https://vaultedmetrics.io/

Proof of Concept: The below screenshots depict that the application is vulnerable to clickjacking attack.



Recommendation

It is recommended to implement proper clickjacking protection across the web application by configuring security headers that prevent the application from being embedded in untrusted frames. Specifically, the X-Frame-Options header should be set to DENY or SAMEORIGIN, and the Content-Security-Policy header should include a properly configured frame-ancestors directive restricting framing to trusted domains.

HSHM – HTTP Security Headers Misconfigured

Criticality	Minor / Informative
Status	Unresolved
CWE ID:	693
CVSS3 Score:	3.1

Description

It is observed that the web application implements HTTP security headers; however, certain headers are misconfigured or inconsistently applied. Specifically, the Content-Security-Policy (CSP) header contains overly permissive directives and/or insecure configurations that may reduce its effectiveness in mitigating client-side attacks. Additionally, duplicate security headers are present in HTTP responses.

A misconfigured CSP may allow the execution of untrusted scripts, unsafe inline code, or resources from untrusted origins, thereby weakening protection against Cross-Site Scripting (XSS) and other injection-based attacks. The presence of duplicate headers may lead to inconsistent behavior across browsers, as different browsers may interpret multiple header values differently. This can result in unintended security bypasses or reduced effectiveness of the intended protections.

Vulnerable URL / HOST:

- https://vaultedmetrics.io/

Proof of Concept: The screenshots below depict the HTTP response showing a misconfigured Content-Security-Policy.

Send Cancel Target: https://vaultedmetrics.io HTTP/2

Request

```
GET /litepaper.html HTTP/2
Host: vaultedmetrics.io
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0) Gecko/20100101
Firefox/147.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Referer: https://vaultedmetrics.io/
Cookie: _tccl_visitor=bd196439-8a8f-4580-917d-a4eb908dfef9; _tccl_visit=
bd196439-8a8f-4580-917d-a4eb908dfef9; _scc_session=
pc=2&C_TOUCH=2026-03-02T04:40:20.468Z
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Accept-Encoding: gzip, deflate, br
```

Response

```
HTTP/2 200 OK
Date: Mon, 02 Mar 2026 04:43:40 GMT
Content-Type: text/html
Content-Length: 53421
X-Sucuri-Id: 19022
X-Xss-Protection: 1; mode=block
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Content-Security-Policy: upgrade-insecure-requests;
Last-Modified: Tue, 24 Feb 2026 23:13:26 GMT
Etag: "25a0138-cee7-64b9a08e66f5b-br"
Cache-Control: max-age=3600
Expires: Mon, 02 Mar 2026 05:43:03 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Xss-Protection: 1; mode=block
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=()
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'
https://cdnjs.cloudflare.com https://img1.wsimg.com
https://static.cloudflareinsights.com https://ajax.cloudflare.com; style-src 'self'
'unsafe-inline' https://cdnjs.cloudflare.com https://fonts.googleapis.com; font-src
'self' https://fonts.gstatic.com https://cdnjs.cloudflare.com; img-src 'self' data:;
connect-src 'self' https://discord.gg https://csp.secureserver.net;
X-Permitted-Cross-Domain-Policies: none
Server: Sucuri/Cloudproxy
X-Sucuri-Cache: HIT
Alt-Svc: h3=":443"; ma=2592000, h3-29=":443"; ma=2592000
Accept-Ranges: bytes
```

Send Cancel Target: https://vaultedmetrics.io HTTP/2

Request

```
OPTIONS /ecosystem.html HTTP/2
Host: vaultedmetrics.io
Cookie: _tccl_visitor=07f81cce-4073-4639-8333-3641c57396eb; _tccl_visit=
07f81cce-4073-4639-8333-3641c57396eb; _scc_session=
pc=2&C_TOUCH=2026-03-04T08:39:06.616Z
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:148.0) Gecko/20100101
Firefox/148.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate
Referer: https://vaultedmetrics.io/
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
If-Modified-Since: Tue, 24 Feb 2026 23:12:29 GMT
If-None-Match: "25a01a2-9900-64b9a057a40ce-gzip"
Priority: u=0, i
Te: trailers
```

Response

```
HTTP/2 403 Forbidden
Date: Wed, 04 Mar 2026 09:14:54 GMT
Content-Type: text/html
X-Sucuri-Id: 19022
X-Xss-Protection: 1; mode=block
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Content-Security-Policy: upgrade-insecure-requests;
X-Sucuri-Block: METO43
Server: Sucuri/Cloudproxy

<!DOCTYPE html>
<html lang="en" xmlns="http://www.w3.org/1999/xhtml">
<head>
<link rel="stylesheet" href="
https://cdn.sucuri.net/css/whitelabel/typography.css?611e1e2" />
<link rel="stylesheet" href="https://cdn.sucuri.net/css/whitelabel.css?611e1e2
" />
<link rel="stylesheet" href="
https://cdn.sucuri.net/css/whitelabel/buttons.css?611e1e2" />
<link rel="stylesheet" href="
https://cdn.sucuri.net/css/whitelabel/footer.css?611e1e2" />
<link rel="stylesheet" href="
https://cdn.sucuri.net/css/whitelabel/header.css?611e1e2" />
<link rel="stylesheet" href="https://cdn.sucuri.net/css/fonts.css" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>GoDaddy Security - Access Denied</title>
</head>
<body>
<header class="app-header clearfix">
<div class="wrap"><a href="https://www.godaddy.com/" class="logo"></a>
<span class="logo-neartext">Security</span>
```

Additional Proof of Concept: The screenshot below depicts the HTTP response showing duplicate security headers, like X-Xss-Protection, X-Frame-Options & Content-Security-Policy.

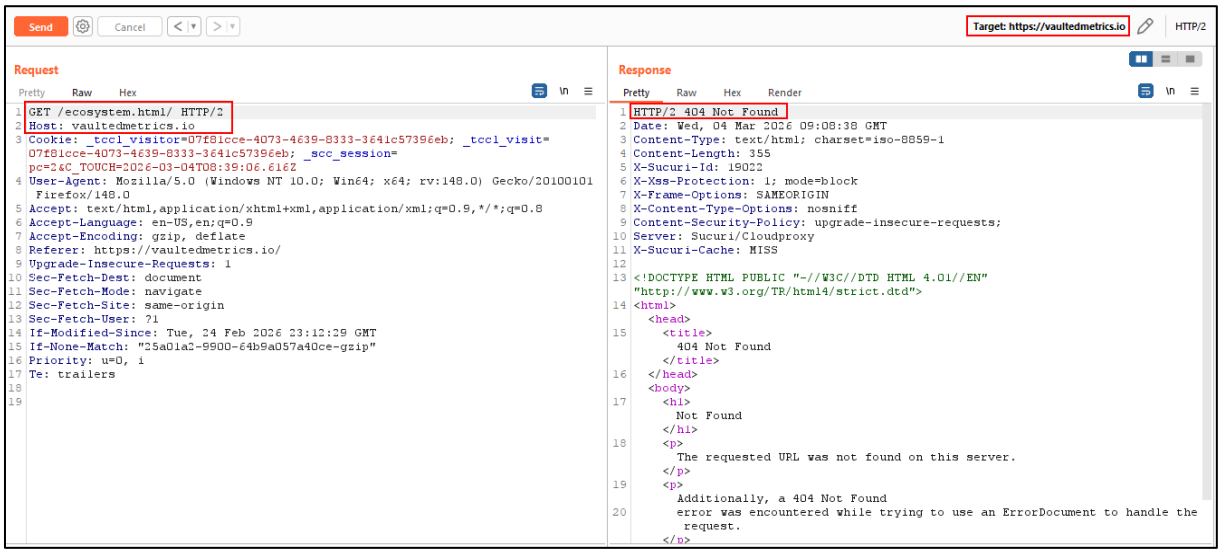
Request

```
GET /tokenomics.html HTTP/2
Host: vaultedmetrics.io
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:148.0) Gecko/20100101
Firefox/148.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
Cookie: _tccl_visitor=bd196439-8a8f-4580-917d-a4eb908dfef9
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
Accept-Encoding: gzip, deflate, br
```

Response

```
HTTP/2 200 OK
Date: Tue, 03 Mar 2026 07:21:08 GMT
Content-Type: text/html
Content-Length: 63104
X-Sucuri-Id: 19022
X-Xss-Protection: 1; mode=block
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Content-Security-Policy: upgrade-insecure-requests;
Last-Modified: Tue, 24 Feb 2026 23:16:04 GMT
Etag: "25a0105-f4ba-64b9a12480bc9-br"
Cache-Control: max-age=3600
Expires: Tue, 03 Mar 2026 08:21:08 GMT
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Xss-Protection: 1; mode=block
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=()
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline'
https://cdnjs.cloudflare.com https://img1.wsimg.com
https://static.cloudflareinsights.com https://ajax.cloudflare.com; style-src 'self'
'unsafe-inline' https://cdnjs.cloudflare.com https://fonts.googleapis.com; font-src
'self' https://fonts.gstatic.com https://cdnjs.cloudflare.com; img-src 'self' data:;
connect-src 'self' https://discord.gg https://csp.secureserver.net;
X-Permitted-Cross-Domain-Policies: none
Server: Sucuri/Cloudproxy
X-Sucuri-Cache: MISS
Alt-Svc: h3=":443"; ma=2592000, h3-29=":443"; ma=2592000
Accept-Ranges: bytes
```

Additional Proof of Concept: The screenshot below depicts the HTTP response showing HTTP Strict Transport Security (HSTS) is not implemented.



Recommendation

It is recommended to review and update the configuration of HTTP security headers across the application to ensure they are properly implemented and aligned with security best practices. The **Content Security Policy (CSP)** should be carefully reviewed and strengthened by avoiding overly permissive directives, minimizing the use of unsafe keywords unless absolutely necessary, and restricting resource loading to trusted and explicitly defined sources. Additionally, duplicate security headers should be removed to ensure that only a single, consistent header value is returned in each HTTP response, preventing inconsistent browser behavior and potential security bypasses. Furthermore, it is recommended to implement **HTTP Strict Transport Security (HSTS)** to enforce secure HTTPS connections and enhance protection against downgrade and man-in-the-middle attacks.

SCE - SSL Certificate Expiration

Criticality	Minor / Informative
Status	Unresolved
CWE ID:	295
CVSS3 Score:	0.0

Description

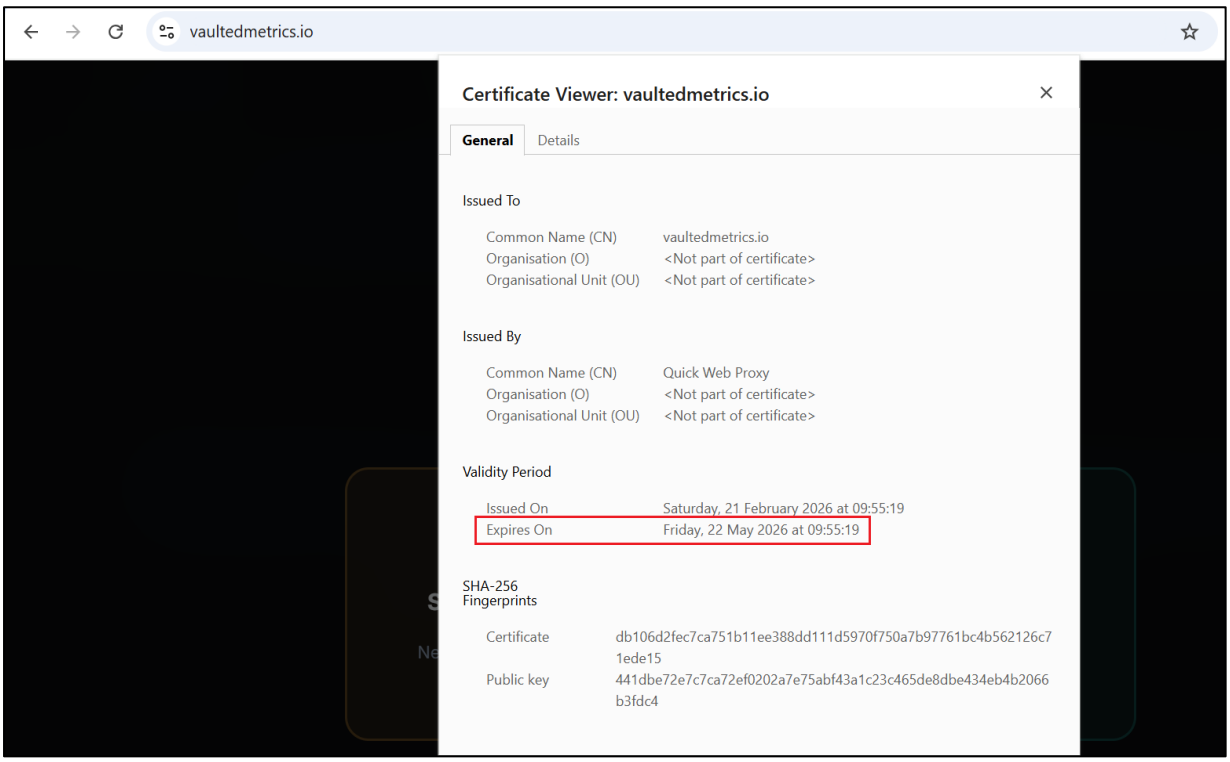
The SSL/TLS certificate used by the web application has a defined validity period and will expire after the specified date. If the certificate is not renewed before expiration, browsers and clients will no longer trust the secure connection and may display security warnings to users. This can lead to interruptions in secure communication and reduce user confidence in the website's security.

An expired SSL certificate may cause browsers to block access or display security warnings, which can prevent users from securely accessing the application. It may also affect automated services, APIs, or integrations that rely on secure HTTPS communication. While this issue does not directly expose sensitive data, it can disrupt service availability and reduce trust in the application

Vulnerable URL / HOST:

- https://vaultedmetrics.io/

Proof of Concept: The below screenshot depicts that the application is vulnerable to SSL certificate expiration.



Recommendation

It is recommended to monitor the SSL/TLS certificate validity period and renew the certificate before its expiration date. Organizations should implement automated certificate renewal mechanisms where possible and maintain proper certificate management processes to ensure uninterrupted secure communication.

Summary

The report provides a comprehensive assessment of the web application's security posture from a black-box perspective, simulating real-world attack scenarios without prior knowledge of the internal architecture. Through systematic external testing, it evaluates exposed endpoints, application behavior, configuration settings, transport security, and client-side controls to identify vulnerabilities that could be exploited by an unauthenticated attacker. The assessment highlights weaknesses in publicly accessible components and reviews the effectiveness of implemented security mechanisms in protecting the application from external threats.

Overall, the report serves as a strategic resource by outlining the application's externally observable risk exposure and providing actionable remediation guidance to address identified security gaps. By implementing the recommended measures, the organization can reduce its attack surface, strengthen its resilience against opportunistic and targeted attacks, and enhance overall confidence in the application's security posture among stakeholders and end users.

Disclaimer

The information provided in this report does not constitute investment, financial or trading advice and you should not treat any of the document's content as such. This report may not be transmitted, disclosed, referred to or relied upon by any person for any purposes nor may copies be delivered to any other person other than the Company without Cyberscope's prior written consent. This report is not nor should be considered an "endorsement" or "disapproval" of any particular project or team. This report is not nor should be regarded as an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Cyberscope to perform a security assessment. This document does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors' business, business model or legal compliance. This report should not be used in any way to make decisions around investment or involvement with any particular project. This report represents an extensive assessment process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk Cyberscope's position is that each company and individual are responsible for their own due diligence and continuous security Cyberscope's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies and in no way claims any guarantee of security or functionality of the technology we agree to analyze. The assessment services provided by Cyberscope are subject to dependencies and are under continuing development. You agree that your access and/or use including but not limited to any services reports and materials will be at your sole risk on an as-is where-is and as-available basis Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives and other unpredictable results. The services may access and depend upon multiple layers of third parties.

About Cyberscope

Cyberscope is a TAC blockchain cybersecurity company that was founded with the vision to make web3.0 a safer place for investors and developers. Since its launch, it has worked with thousands of projects and is estimated to have secured tens of millions of investors' funds.

Cyberscope is one of the leading smart contract audit firms in the crypto space and has built a high-profile network of clients and partners.

A **TAC Security** Company

The Cyberscope team

cyberscope.io